

YellowKey & GreenPlasma

Windows BitLocker Bypass & CTFMON Privilege Escalation — Dual Zero-Day Disclosure

Threat Intelligence Report | Published: May 13, 2026 | Lost Boys Cyber

YellowKey — BitLocker Bypass

Attribute	Detail
Vulnerability Name	YellowKey
CVE ID	Unassigned — Zero-Day (No CVE as of 13 May 2026)
Disclosure Date	12 May 2026 — GitHub (Nightmare-Eclipse / Chaotic Eclipse)
Vulnerability Type	WinRE Component Abuse → BitLocker Full-Disk Encryption Bypass
Affected Component	Windows Recovery Environment (WinRE) — FsTx Directory Handler
CVSSv3 Score	Not Yet Assigned Analyst Estimate: ~7.5 High (Physical vector)
Attack Vector	Physical — USB stick or direct EFI partition write access
Authentication	None required
Privileges Required	None — any physical access is sufficient
Exploit Status	Public PoC Available — Independently reproduced (KevTheHermit, 13 May 2026)
Zero-Day	Yes — No patch issued, no CVE assigned
Patch Available	No — Awaiting Microsoft response

GreenPlasma — CTFMON Privilege Escalation

Attribute	Detail
Vulnerability Name	GreenPlasma
CVE ID	Unassigned — Zero-Day (No CVE as of 13 May 2026)
Disclosure Date	12 May 2026 — GitHub (Nightmare-Eclipse / Chaotic Eclipse)
Vulnerability Type	Arbitrary Memory Section Object Creation → Local Privilege Escalation to SYSTEM
Affected Component	ctfmon.exe (CTF Monitor) — Windows Text Input Subsystem
CVSSv3 Score	Not Yet Assigned Analyst Estimate: ~7.8 High (Local vector)
Attack Vector	Local — requires an existing low-privilege foothold on the target
Authentication	Low-privileged user account required
Privileges Required	Low
Exploit Status	Partial PoC Released — Final escalation code withheld; weaponisation requires further development
Zero-Day	Yes — No patch issued, no CVE assigned
Patch Available	No — No known mitigation from Microsoft

⚠️ AI-ASSISTED REPORT — IMPORTANT DISCLOSURE

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All content, findings, detection rules, and recommendations must be independently reviewed and validated by a qualified security professional before being acted upon or implemented in any environment.

Query Disclaimer: All detection queries (Sigma, KQL, PowerShell, SPL) included in this report are generic templates. They require adaptation to match your organisation's specific environment, data sources, field names, log formats, and SIEM/EDR platform configuration.

Currency: Information in this report is based on publicly available sources as of 13 May 2026. Both vulnerabilities are unpatched zero-days — threat intelligence evolves rapidly. Verify all details against GitHub disclosures, vendor advisories,

and CISA guidance before relying on this document.

1. Executive Summary

On 12 May 2026, the day of Microsoft's monthly Patch Tuesday release, an anonymous security researcher operating under the aliases Nightmare-Eclipse and Chaotic Eclipse publicly disclosed two unpatched zero-day vulnerabilities targeting Microsoft Windows: YellowKey and GreenPlasma. Neither vulnerability has received a CVE identifier, and Microsoft has not issued a public acknowledgement or patch as of the date of this report.

YellowKey is a critical BitLocker encryption bypass. By placing a specific directory structure named FsTx onto a USB stick (or the EFI System Partition) and holding the CTRL key during a reboot into the Windows Recovery Environment, an attacker with physical access obtains an unrestricted command shell with full read/write access to a BitLocker-protected volume — without the recovery key or PIN. Independent reproduction has already been confirmed. The researcher claims the flaw exists only in the WinRE image (not in the main Windows installation) and describes it as a potential intentional backdoor, a claim that cannot be independently verified at this time. Windows 11, Server 2022, and Server 2025 are affected; Windows 10 is not.

GreenPlasma is a local privilege escalation (LPE) that exploits arbitrary memory-section object creation in directory objects writable by SYSTEM, targeting the ctfmon.exe (CTF Monitor) process. A successful exploit grants an unprivileged local user full SYSTEM access. The researcher released only partial proof-of-concept code — the final escalation component was withheld — however, security experts warn that weaponisation is feasible for a skilled attacker. In its current state the PoC triggers a UAC consent prompt, but a silent exploit is considered achievable with further development.

These disclosures are part of an ongoing retaliatory campaign by Nightmare-Eclipse against Microsoft, following an alleged violation of a prior agreement. Earlier releases in the same series — RedSun, UnDefend, and BlueHammer — have already been observed in real-world intrusions. The researcher has explicitly threatened further disclosures, including a 'big surprise' on the next Patch Tuesday and claimed RCE-class bugs held in reserve. Organisations should treat both vulnerabilities as active threats and implement the mitigations in Section 4 immediately.

2. Vulnerability Details

2.1 YellowKey — Root Cause

YellowKey exploits a component present exclusively inside the Windows Recovery Environment (WinRE) image. The vulnerable component reacts to the presence of a specific folder structure — System Volume Information\FsTx\<GUID>\ — on any attached storage medium (including USB drives or the EFI System Partition). When this structure is detected during a WinRE boot sequence and the CTRL key is held, the component spawns a command shell with unrestricted access to the decrypted volume contents.

The critical observation is that a component with the same name exists in the main Windows OS image but lacks the FsTx-triggered functionality. This divergence between the WinRE and production binaries is the basis for the researcher's backdoor allegation. The EFI System Partition (ESP) is not encrypted by

BitLocker by default, providing an alternative attack path that requires no external media — only the ability to temporarily remove and re-attach the target disk.

Attack steps (USB method):

- Format a USB stick as NTFS (FAT32/exFAT also work).
- Copy the FsTx directory structure from the YellowKey repository to: <USB>:\System Volume Information\FsTx\<GUID>\
- Insert the USB stick into the target Windows 11 / Server 2022/2025 machine.
- Hold Shift and click Restart to boot into the Windows Recovery Environment.
- Immediately release Shift, then hold CTRL and maintain it throughout the boot.
- A command prompt opens with unrestricted access to the BitLocker-protected volume.
- Use diskpart to mount and browse the decrypted drive.

2.2 YellowKey — Affected Products

Confirmed affected: Windows 11 (all builds tested, including 10.0.26100.1), Windows Server 2022, Windows Server 2025. Windows 10 is NOT affected — the WinRE component in Windows 10 lacks the FsTx-triggered functionality. The researcher has stated that TPM+PIN configurations are also vulnerable but has declined to release that variant of the exploit.

2.3 GreenPlasma — Root Cause

GreenPlasma targets ctfdmon.exe, the CTF Monitor, which runs as a SYSTEM-level process in every interactive Windows session to support text input services (handwriting recognition, IMEs, etc.). The vulnerability arises from the ability of an unprivileged user to create arbitrary memory-section objects within directory objects that are writeable by SYSTEM. Because many Windows services and kernel-mode drivers implicitly trust data originating from these directory paths without additional validation, a crafted section object can be used to influence privileged processes and ultimately achieve a SYSTEM-level token.

The researcher released C++ source code (GreenPlasma.cpp) demonstrating the section-object creation primitive and the mechanism for targeting ctfdmon.exe, but stripped the final token-manipulation component that completes the SYSTEM escalation. In its published form, the exploit surfaces a UAC consent dialogue rather than a silent elevation. Security experts assess that weaponisation of the complete chain is feasible for an experienced threat actor.

2.4 GreenPlasma — Affected Products

Confirmed affected: Windows 11, Windows Server 2022, Windows Server 2026. Affected scope is any system running ctfdmon.exe (i.e., all interactive desktop sessions). No affected version list has been published by Microsoft at time of writing.

2.5 Combined Attack Chain

While YellowKey and GreenPlasma are distinct vulnerabilities, they are complementary in an attacker's toolkit. An attacker who uses YellowKey to access a BitLocker-protected endpoint (e.g. a stolen corporate laptop) can extract local credentials or plant a backdoor. If those credentials allow remote login to a corporate asset, GreenPlasma can be used post-access to escalate from a standard user account to SYSTEM — enabling credential dumping, EDR tampering, and lateral movement.

3. Threat Landscape & Context

Both vulnerabilities originate from a single anonymous threat actor operating as Nightmare-Eclipse / Chaotic Eclipse / Dead Eclipse, widely rumoured within the security community to be a former Microsoft employee. The disclosures are explicitly framed as retaliation: the researcher's blog post states that "someone violated our agreement and left me homeless with nothing" and that the leak campaign was the direct consequence of this. Each release has been precisely timed — the YellowKey and GreenPlasma drops came the same day as Microsoft's May 2026 Patch Tuesday, maximising media attention and minimising the gap between disclosure and available patch.

This researcher's prior disclosures — RedSun (Windows Defender admin privilege escalation) and UnDefend (denial-of-service) — were picked up and actively weaponised within days of publication, as confirmed by Huntress incident responders. BlueHammer (CVE-2026-32201, a SharePoint spoofing bug) was patched in April 2026. The pattern is consistent: each drop is technically credible, receives independent verification quickly, and attracts fork activity on GitHub that accelerates weaponisation.

For YellowKey specifically, the implications for enterprise device loss policies are significant. BitLocker in TPM-only mode — the default for consumer and many enterprise builds — is the primary data-at-rest control cited in NIS2, DORA, and GDPR breach-notification assessments. A confirmed bypass changes the risk calculus for stolen or lost devices: what was previously a "hardware loss" incident may now constitute a data breach requiring regulatory notification. Organisations should review their incident response playbooks accordingly.

The researcher has explicitly promised further disclosures: "Next patch Tuesday will have a big surprise for you, Microsoft" and claims to hold RCE-class bugs in reserve as a dead man's switch. Given the perfect delivery record to date, this threat should be treated as credible.

4. Mitigation

Mitigations are listed in priority order. No vendor patch is available for either vulnerability. All controls below reduce attack surface but cannot fully eliminate risk until Microsoft issues fixes.

4.1 YellowKey — Enable BitLocker TPM + PIN (Highest Priority)

Configure BitLocker to require a PIN at pre-boot in addition to the TPM, using Group Policy: Computer Configuration > Administrative Templates > Windows Components > BitLocker Drive Encryption > Operating System Drives > Require additional authentication at startup. Note: the researcher has claimed that TPM+PIN does not fully protect against YellowKey but has not released that variant. Until independently verified, TPM+PIN remains the best available control and should be deployed immediately. Monitor for updated researcher disclosures.

```
manage-bde -protectors -add C: -TPMAndPIN
manage-bde -protectors -get C: # Verify TPMAndPIN is listed
```

4.2 YellowKey — Lock Down Boot Order and Harden WinRE

Set a BIOS/UEFI supervisor password and disable USB boot in firmware. This prevents the USB-stick attack vector entirely. Additionally, where WinRE is not required for operational recovery, consider disabling it (note: this may impact Windows Update recovery capabilities):

```
reagentc /disable # Disables WinRE – verify update impacts before deploying
reagentc /info # Verify current WinRE status
```

4.3 YellowKey — Treat All Lost/Stolen Devices as Breached

Until a vendor patch is available, revise device loss incident response procedures to assume data accessibility regardless of BitLocker status. Initiate GDPR Art. 33 breach notification assessment for any lost device running Windows 11 or Server 2022/2025. Revoke any credentials that may have been cached on the device (LAPS passwords, domain cached credentials, certificate private keys).

4.4 GreenPlasma — Privilege Restriction and Monitoring

No direct mitigation is available for GreenPlasma. Apply defence-in-depth controls to limit post-exploitation impact: enforce least-privilege user accounts, deploy Microsoft's Protected Users security group for privileged accounts, enable Credential Guard to protect LSASS, and ensure EDR solutions have visibility into ctfmon.exe child process creation and memory section creation events. Monitor for anomalous SYSTEM tokens originating from user-context processes.

4.5 Enable Attack Surface Reduction (ASR) Rules

Enable ASR rules in Audit mode first, then enforce: 'Block credential stealing from the Windows local security authority subsystem' (GUID: 9e6c4e1f-7d60-472f-ba1a-a39ef669e4b0) and 'Block process creations originating from PSEXEC and WMI commands' to limit lateral movement post-exploitation. These do not block GreenPlasma directly but reduce the attacker's ability to leverage SYSTEM access.

5. Detection

5.1 YellowKey — Endpoint Indicators

The primary host-based indicator is the presence of a 'System Volume Information\FsTx' directory structure on any attached volume (internal or external). Legitimate Windows installations do not create this path. Additional indicators include unexpected diskpart or diskpart.exe invocations during or immediately after a WinRE session, and cmd.exe processes spawned from WinRE-associated processes with unusual parent lineage.

```
# PowerShell: Scan all volumes for FsTx indicator
Get-PSDrive -PSProvider FileSystem | ForEach-Object {
    $path = Join-Path $_.Root 'System Volume Information\FsTx'
    if (Test-Path $path) {
        Write-Warning "INDICATOR FOUND: $path"
        Get-ChildItem -Force $path | Select FullName,Length,CreationTime
    }
}
```

5.2 GreenPlasma — Endpoint Indicators

Monitor for anomalous behaviour from ctfmon.exe: unexpected child process creation, memory section objects created by user-context processes in SYSTEM-accessible directory objects (NtCreateSection calls to \BaseNamedObjects or similar), and processes running with SYSTEM tokens that were originally started by a standard user. EDR telemetry should flag NtCreateSection calls from low-integrity processes into high-integrity directory objects.

5.3 Sigma Rule — YellowKey FsTx Structure Detection

```
title: YellowKey FsTx BitLocker Bypass Indicator
id: a3f72b91-cc4e-4d8a-b201-5e3a11f8d902
status: experimental
description: Detects creation of FsTx directory structure used in YellowKey
BitLocker bypass
author: Lost Boys Cyber
date: 2026-05-13
logsource:
  category: file_event
  product: windows
detection:
  selection:
    TargetFilename|contains: '\\System Volume Information\\FsTx\\'
  condition: selection
falsepositives:
  - None known – this path should not exist in legitimate environments
level: critical
tags:
  - attack.defense_evasion
  - attack.t1006
```

5.4 Sigma Rule — GreenPlasma Suspicious ctfmon Child Process

```
title: GreenPlasma – Suspicious Child Process from ctfmon.exe
id: b9d14c38-ff72-4a1e-9b44-c83e24f61d08
status: experimental
description: Detects unusual child processes spawned by ctfmon.exe, indicative of
GreenPlasma exploitation
author: Lost Boys Cyber
date: 2026-05-13
logsource:
  category: process_creation
  product: windows
detection:
  selection:
    ParentImage|endswith: '\\ctfmon.exe'
    Image|endswith:
      - '\\cmd.exe'
      - '\\powershell.exe'
      - '\\pwsh.exe'
      - '\\wscript.exe'
      - '\\cscript.exe'
      - '\\mshta.exe'
  condition: selection
falsepositives:
  - Rare legitimate accessibility tooling – validate against baseline
level: high
```

```
tags:
  - attack.privilege_escalation
  - attack.t1068
```

5.5 Microsoft Sentinel / MDE KQL Queries

YellowKey — FsTx file creation:

```
DeviceFileEvents
| where TimeGenerated > ago(7d)
| where FolderPath has 'System Volume Information\FsTx'
| project TimeGenerated, DeviceName, InitiatingProcessFileName,
          FolderPath, FileName, ActionType
| order by TimeGenerated desc
```

GreenPlasma — ctfmon.exe spawning shells:

```
DeviceProcessEvents
| where TimeGenerated > ago(7d)
| where InitiatingProcessFileName =~ 'ctfmon.exe'
| where FileName in~ ('cmd.exe', 'powershell.exe', 'pwsh.exe',
                     'wscript.exe', 'cscript.exe', 'mshta.exe')
| project TimeGenerated, DeviceName, AccountName,
          InitiatingProcessFileName, FileName, ProcessCommandLine
| order by TimeGenerated desc
```

6. Threat Hunting

6.1 Hunt: FsTx Structures on Enterprise Endpoints

Deploy the following PowerShell as a scheduled task or via your endpoint management platform (Intune, SCCM) to scan all Windows 11/Server 2022/2025 endpoints for the YellowKey indicator. Alert on any positive result — there are no known legitimate use cases for this path.

```
# Deploy via Intune/MEM as a detection script
$indicator = $false
Get-PSDrive -PSProvider FileSystem | ForEach-Object {
    $p = Join-Path $_.Root 'System Volume Information\FsTx'
    if (Test-Path $p) { $indicator = $true }
}
if ($indicator) { exit 1 } else { exit 0 } # exit 1 = non-compliant
```

6.2 Hunt: SYSTEM Tokens from Standard User Processes

Hunt for processes that escalated to SYSTEM from a standard user session — a key post-exploitation indicator for GreenPlasma and similar LPE techniques. Use Windows Security Event ID 4672 (special privileges assigned to new logon) correlated with the originating session.

```
// Sentinel KQL – SYSTEM privileges assigned to non-standard processes
SecurityEvent
| where EventID == 4672
```



```
| where AccountName !in ('SYSTEM','LOCAL SERVICE','NETWORK SERVICE')
| where PrivilegeList has 'SeDebugPrivilege'
| project TimeGenerated, Computer, AccountName, PrivilegeList
| order by TimeGenerated desc
```

6.3 Hunt: WinRE Boot Events Followed by Disk Activity

Correlate Windows Recovery Environment boot events (Event ID 20001 from Microsoft-Windows-ReAgent/Operational) with subsequent diskpart or unusual disk access within a 10-minute window. This pattern is consistent with YellowKey exploitation on a device that remained network-connected.

```
// Sentinel KQL – WinRE events correlated with diskpart
let winre = Event | where Source == 'Microsoft-Windows-ReAgent'
| where EventID == 20001 | project TimeGenerated, Computer;
let diskpart = DeviceProcessEvents
| where FileName =~ 'diskpart.exe' | project TimeGenerated, DeviceName;
winre | join kind=inner (diskpart) on $left.Computer == $right.DeviceName
| where abs(datetime_diff('minute', TimeGenerated, TimeGenerated1)) <= 10
```

6.4 Hunt: Persistence Mechanisms Post-Exploitation

Following a successful GreenPlasma SYSTEM escalation, threat actors commonly establish persistence via scheduled tasks, registry run keys, or service creation. Hunt for scheduled tasks created by non-SYSTEM accounts after privilege escalation events, and new services with suspicious binary paths.

```
// KQL – Scheduled tasks created by unusual accounts
SecurityEvent | where EventID == 4698 // A scheduled task was created
| where SubjectUserName !in~ ('SYSTEM','Administrator')
| project TimeGenerated, Computer, SubjectUserName, TaskName, TaskContent
```

6.5 Hunt: Credential Harvesting Following LPE

SYSTEM access from GreenPlasma enables direct LSASS credential dumping without Mimikatz if Credential Guard is not enabled. Hunt for lsass.exe memory reads from non-expected processes, particularly processes that recently elevated from standard user to SYSTEM.

```
// KQL – LSASS access from suspicious processes
DeviceEvents
| where ActionType == 'OpenProcess'
| where TargetProcessFileName =~ 'lsass.exe'
| where InitiatingProcessFileName !in~
('MsMpEng.exe','csrss.exe','wininit.exe','svchost.exe','lsm.exe')
| project TimeGenerated, DeviceName, InitiatingProcessFileName,
InitiatingProcessCommandLine, AccountName
```

7. MITRE ATT&CK Mapping

Tactic	ID	Technique	Application
Initial Access / Collection	T1200	Hardware Additions	YellowKey: USB stick carrying FsTx payload inserted into target machine
Defense Evasion	T1006	Direct Volume Access	YellowKey: Shell gains raw

			access to BitLocker-decrypted volume bypassing OS controls
Defense Evasion	T1542.001	Pre-OS Boot: System Firmware	YellowKey: Exploits WinRE (pre-OS environment) before main OS security controls load
Privilege Escalation	T1068	Exploitation for Privilege Escalation	GreenPlasma: Exploits ctfmon.exe section-object vulnerability to obtain SYSTEM token
Privilege Escalation	T1134	Access Token Manipulation	GreenPlasma: Manipulates process tokens to escalate from standard user to SYSTEM
Credential Access	T1003.001	OS Credential Dumping: LSASS Memory	Post-exploitation: SYSTEM access enables LSASS dump without additional tools if Credential Guard absent
Lateral Movement	T1550.002	Use Alternate Authentication Material: Pass the Hash	Post-exploitation: Harvested NTLM hashes from LSASS used for lateral movement
Persistence	T1053.005	Scheduled Task/Job: Scheduled Task	Post-exploitation: Attacker likely creates persistence via scheduled tasks after SYSTEM escalation

8. Recommended Actions Summary

All actions below should begin immediately given the absence of a vendor patch and the confirmed availability of public PoC code for YellowKey.

Action	Owner	Timeframe
Enforce BitLocker TPM+PIN via Group Policy on all Windows 11 endpoints	IT / Endpoint Eng.	Immediate (24 hrs)
Disable USB boot in BIOS/UEFI and set supervisor password	IT / Endpoint Eng.	Immediate (24 hrs)
Update incident response playbook: treat all lost Win11 / Server 2022/2025 devices as data breach	CISO / IR Team	Immediate (24 hrs)
Deploy FsTx detection script to all endpoints via Intune/SCCM	Detection Eng. / SOC	24 hours
Deploy Sigma/KQL rules for YellowKey and GreenPlasma to SIEM/EDR	SOC / Detection Eng.	24-48 hours
Assess GDPR Art. 33 notification obligations for any devices lost since 12 May 2026	Legal / DPO	48 hours
Enable Credential Guard on all eligible endpoints to limit LSASS exposure post-GreenPlasma	IT / Endpoint Eng.	48-72 hours
Apply Protected Users group to all Tier-0 and Tier-1 privileged accounts	IAM / AD Team	72 hours
Monitor GitHub / researcher blog for updated PoC or TPM+PIN bypass release	Threat Intel	Ongoing
Apply Microsoft patch immediately upon release for both vulnerabilities	IT / Patch Mgmt.	On patch release

9. References

Nightmare-Eclipse/YellowKey — GitHub PoC Repository: <https://github.com/Nightmare-Eclipse/YellowKey>

Nightmare-Eclipse/GreenPlasma — GitHub PoC Repository: <https://github.com/Nightmare-Eclipse/GreenPlasma>

The Register — 'Mystery Microsoft bug leaker keeps the zero-days coming' (13 May 2026):

<https://www.theregister.com/security/2026/05/13/disgruntled-researcher-releases-two-more-microsoft-zero-days/>

Bleeping Computer — 'Windows BitLocker zero-day gives access to protected drives, PoC released':

<https://www.bleepingcomputer.com/news/security/windows-bitlocker-zero-day-gives-access-to-protected-drives-poc-released/>

Blackfort Technology — 'YellowKey: BitLocker Bypass Discovered in Windows 11' (13 May 2026): <https://blackfort-tec.de/en/insights/yellowkey-bitlocker-bypass-windows-11-vulnerability>

XDA Developers — 'A new Windows 11 BitLocker bypass only needs a USB stick' (13 May 2026): <https://www.xda-developers.com/new-windows-11-bitlocker-bypass-needs-usb-stick-researcher-backdoor/>

Huntress — 'Nightmare-Eclipse Tooling Seen in Real-World Intrusion': <https://www.huntress.com/blog/nightmare-eclipse-intrusion>

Cybernews — 'Disgruntled researcher strikes Microsoft again' (13 May 2026):

<https://cybernews.com/security/researcher-releases-bitlocker-bypass-and-privilege-escalation-exploit/>

SecurityOnline — 'Exploit Code Released: Public PoC Dumps for Windows BitLocker Bypass and SYSTEM Elevation Zero-Days': <https://securityonline.info/windows-bitlocker-bypass-yellowkey-greenplasma-poc-disclosure/>

Chaotic Eclipse / Dead Eclipse Blog: <https://deadeclipse666.blogspot.com/2026/05/were-doing-silent-patches-now-huh-also.html>

Microsoft Security Response Center — Coordinated Vulnerability Disclosure Policy: <https://www.microsoft.com/en-us/msrc/cvd>

This report was compiled from publicly available threat intelligence sources as of 13 May 2026. Both vulnerabilities are unpatched zero-days — monitor vendor advisories for patch availability. All detection content is provided for defensive purposes and requires environment-specific validation.